

Task 7: Web Application Vulnerability Testing

1) Understand OWASP Top 10:

The OWASP Top 10 is a globally recognized awareness document that identifies the ten most critical web application security risks. Created by the Open Web Application Security Project (OWASP), it is updated every few years based on data from thousands of applications and input from security experts worldwide. The 2025 edition reflects current threats and emphasizes root causes over symptoms.

Top 10 Risks (2025 Edition):

- Broken Access Control
- Security Misconfiguration
- Software Supply Chain Failures
- Cryptographic Failures
- Injection
- Insecure Design
- Authentication Failures
- Software or Data Integrity Failures
- Security Logging & Alerting Failures
- Mishandling of Exceptional Conditions

2) Setup Vulnerable Application:

DVWA:

```
(hari@vbox)-[~]
$ sudo apt update
[sudo] password for hari:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.7 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.1 MB]
51% [3 Contents-amd64 11.9 MB/52.1 MB 23%] 99.9 kB/s 6min 5
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [117 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [268 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [190 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [905 kB]
Fetched 74.2 MB in 10min 57s (113 kB/s)
2067 packages can be upgraded. Run 'apt list --upgradable' to see them.

(hari@vbox)-[~]
$ sudo apt install dvwa -y
Upgrading:
  libapache2-mod-php8.4  libxml2-dev  php8.4  php8.4-common  php8.4-opcache  xz-utils
  liblzma5               libxml2-utils  php8.4-cli  php8.4-mysql  php8.4-readline

Installing:
  dvwa

Installing dependencies:
  liblzma-dev  libxml2-16  php8.4-fpm  php8.4-gd

Suggested packages:
  liblzma-doc  php-pear

Summary:
  Upgrading: 11, Installing: 5, Removing: 0, Not Upgrading: 2056
  Download size: 1,399 kB / 10.7 MB
  Space needed: 10.3 MB / 11.1 GB available

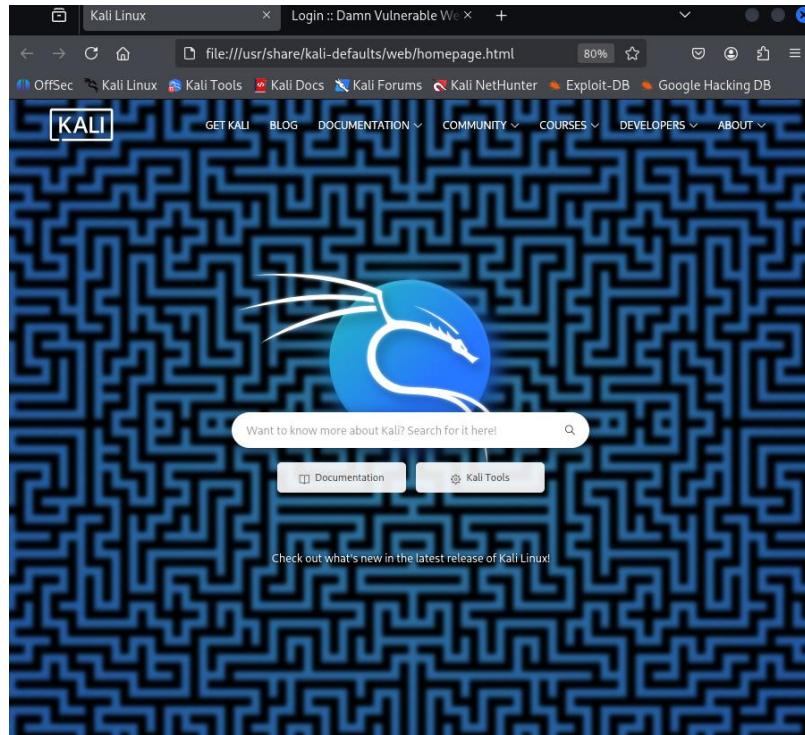
Get:1 http://kali.download/kali kali-rolling/main amd64 liblzma5 amd64 5.8.2-2 [327 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 xz-utils amd64 5.8.2-2 [706 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 liblzma-dev amd64 5.8.2-2 [366 kB]
Fetched 1,399 kB in 4s (319 kB/s)
(Reading database ... 412030 files and directories currently installed.)
Preparing to unpack .../liblzma5_5.8.2-2_amd64.deb ...
Unpacking liblzma5:amd64 (5.8.2-2) over (5.8.1-1) ...
Setting up liblzma5:amd64 (5.8.2-2) ...
(Reading database ... 412030 files and directories currently installed.)
Preparing to unpack .../00-xz-utils_5.8.2-2_amd64.deb ...
Unpacking xz-utils (5.8.2-2) over (5.8.1-1) ...
Preparing to unpack .../01-php8.4-readline_8.4.16-1_amd64.deb ...
Unpacking php8.4-readline (8.4.16-1) over (8.4.6-2) ...
Preparing to unpack .../02-php8.4-opcache_8.4.16-1_amd64.deb ...
Unpacking php8.4-opcache (8.4.16-1) over (8.4.6-2) ...
Preparing to unpack .../03-php8.4-mysql_8.4.16-1_amd64.deb ...
Unpacking php8.4-mysql (8.4.16-1) over (8.4.6-2) ...
```

Start Apache + MySQL:

```
(hari@vbox)-[~]
$ sudo service apache2 start

(hari@vbox)-[~]
$ sudo service mysql start
```

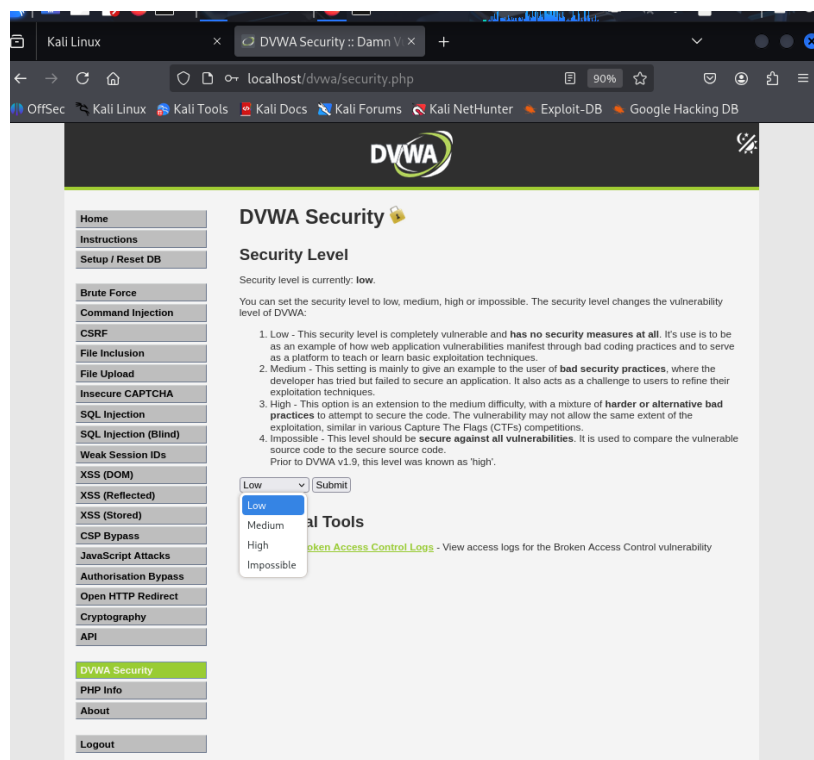
Open browser:



Login:

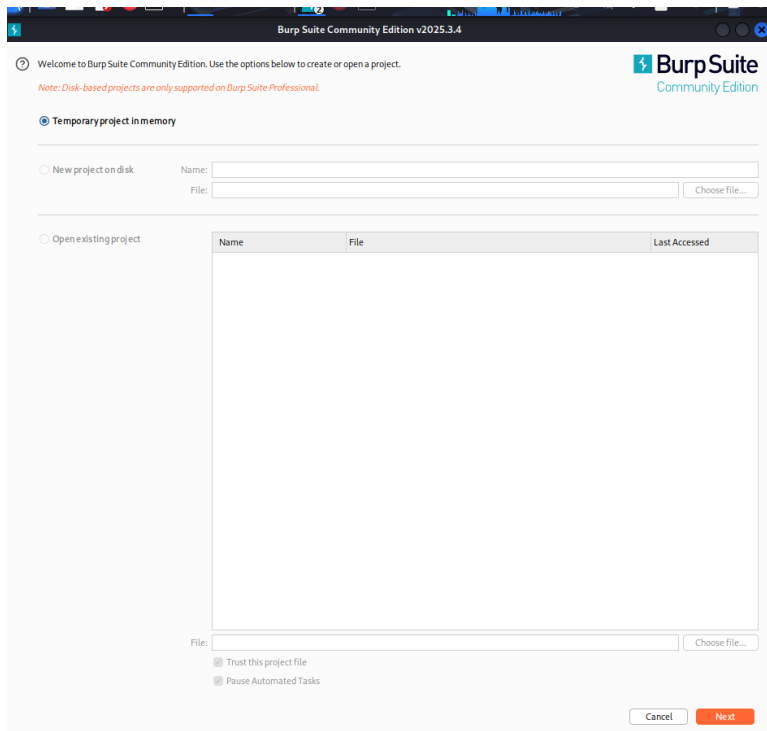
- Username: admin
- Password: password

Set Security Level = Low (for demo).



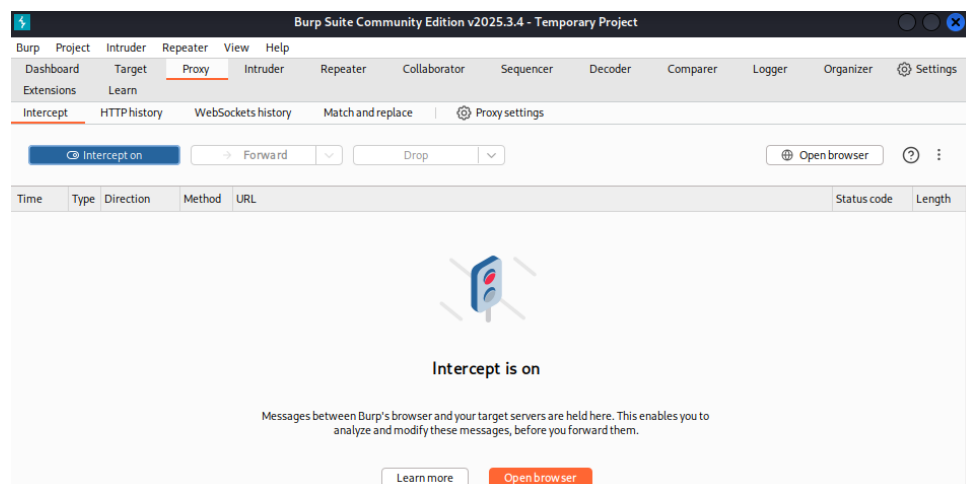
3) Burp Suite Interception:

Turn Burp ON:



Browser proxy set:

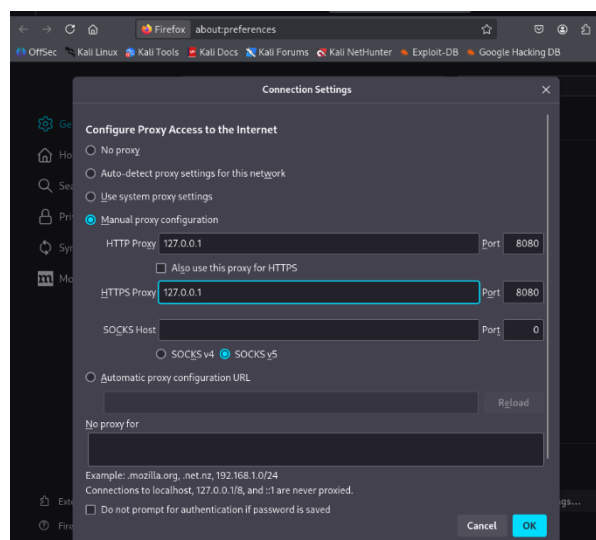
Proxy → Intercept → ON



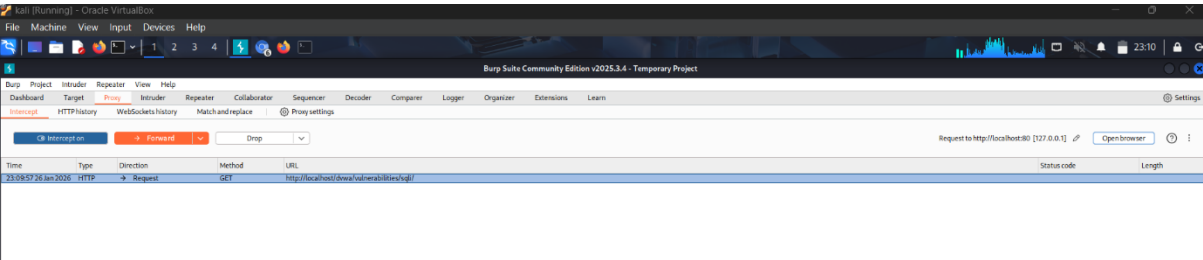
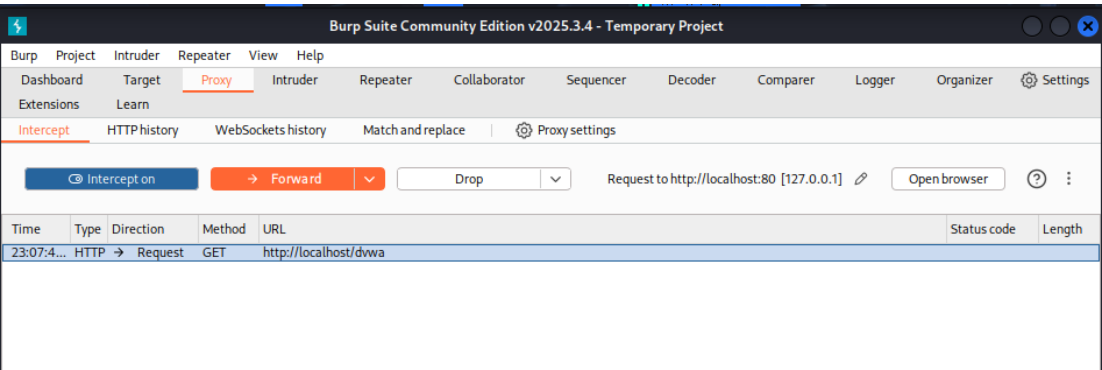
Browser proxy settings

Set proxy:

- IP: 127.0.0.1
- Port: 8080



Browser proxy set:Request Forward

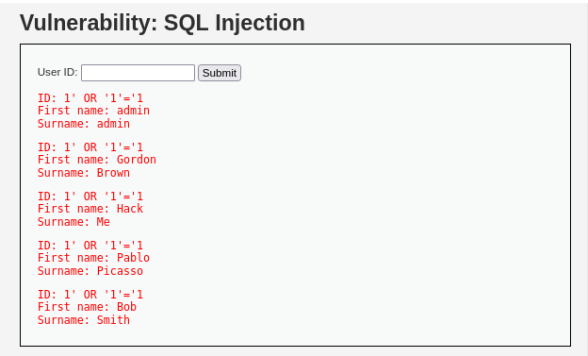


Burp Suite was used to intercept and analyze HTTP requests to confirm vulnerable parameters.

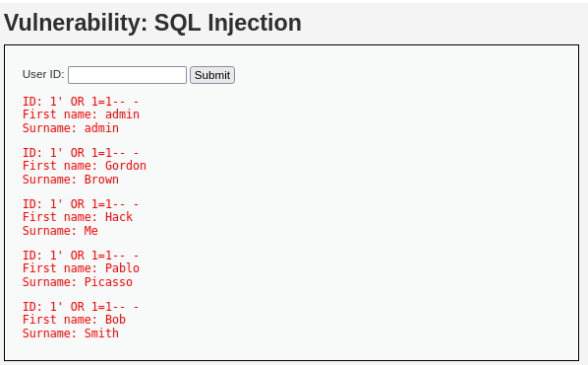
4) Go to SQL Injection:

Now in **User ID**, enter:

1' OR '1'='1



1' OR 1=1-- -



' OR 'a'='a

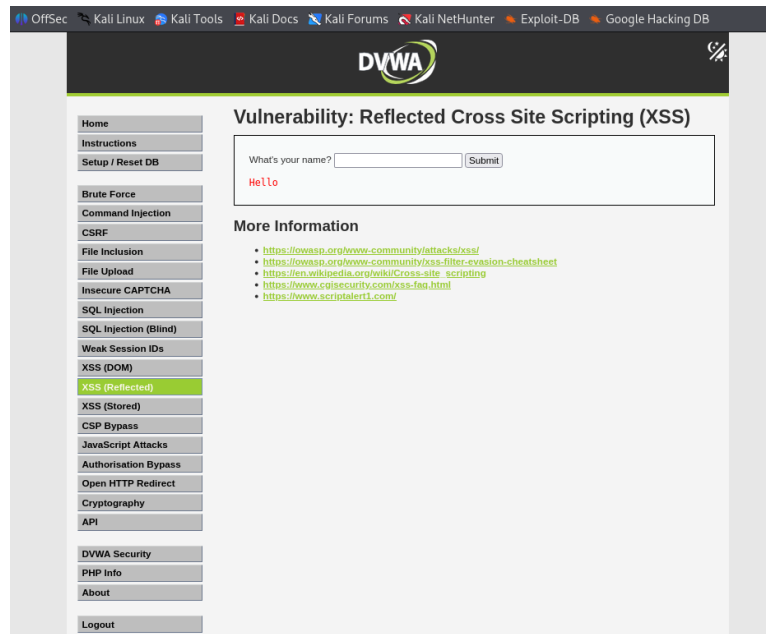
Vulnerability: SQL Injection

User ID:

ID: ' OR 'a'='a
First name: admin
Surname: admin
ID: ' OR 'a'='a
First name: Gordon
Surname: Brown
ID: ' OR 'a'='a
First name: Hack
Surname: Me
ID: ' OR 'a'='a
First name: Pablo
Surname: Picasso
ID: ' OR 'a'='a
First name: Bob
Surname: Smith

5) Manual XSS Testing:

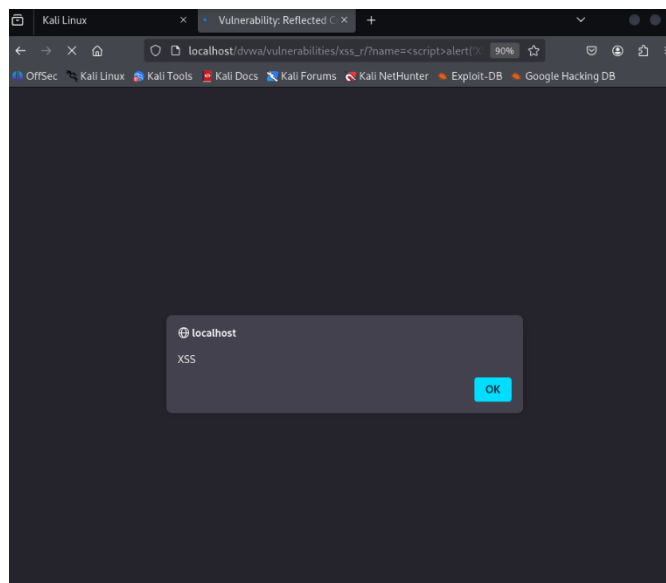
DVWA → XSS (Reflected):



Input:

`<script>alert('XSS')</script>`

6)



7) Vulnerability Table:

Vulnerability	Location	Impact	Severity
SQL Injection	User ID	Data exposure	High
XSS	Input field	Script execution	Medium

Mitigation Recommendations:

SQL Injection:

- Prepared statements
- Input validation
- Least privilege

XSS:

- Input sanitization
- Output encoding
- CSP headers

8) Conclusion:

This assessment demonstrated common web application vulnerabilities such as SQL Injection and XSS. The exercise improved understanding of web application security testing and mitigation techniques.